

김규완

Kyuwan Kim

Security Engineer · 8+ years

SUMMARY

공격자 관점의 모의해킹에서 출발해 제품 보안과 보안 자동화로 전환한 8년차 Security Engineer입니다. AI Agent로 보안 리뷰·펜테스트 워크플로우를 통합해 리뷰 소요 시간을 며칠 → PR 단위로 단축했고, 위협 모델링·Bug Bounty 프로그램 설계·Shift Left SDLC 리뷰로 설계 단계에서 위협을 줄이는 일에 집중합니다.

- SDLC 보안 리뷰 **40+건** 직접 수행, 고위험 설계 이슈를 출시 전 차단
- 거래소 보안 평가(CER) **D → AAA** 견인 (90점, 글로벌 10위) — Server·User Security 보장, Bug Bounty 런칭, 외부 펜 테스트 등 보안 엔지니어 영역 주도
- Bug Bounty 프로그램 **2회** 런칭·운영 (HackerOne, HackenProof)
- AI Agent 기반 **3단계 Security Review 파이프라인** 구축으로 리뷰 시간 며칠 → PR 단위 단축
- 클라우드 네이티브(EKS/GKE) 보안 체계 직접 구축

CORE COMPETENCIES

Offensive · Burp Suite Pro · OWASP ZAP · Frida · Hopper

Automation · Python · FastAPI · Claude AI Agent · MCP · n8n · GitHub Actions · SonarQube · Trivy

Cloud · AWS (EKS, GuardDuty, Inspector, CloudTrail) · GCP (GKE, Cloud Run, BigQuery) · Kubernetes · Terraform

SecOps · CrowdStrike Falcon (MDR, CSPM, Container) · Datadog SIEM · Splunk · Cloudflare WAF

IAM · Okta · 1Password · Active Directory

Compliance · ISO 27001 · ISO 27701 · ISMS-P · CIS Benchmark · VARA

Languages · Python · Shell · TypeScript · JavaScript · SQL · Go

EXPERIENCE

Prex (Flipster) — Security Engineer, Security Team

2024.07 — Present

Prex Technologies Pte Ltd (IC, 2026.01—Present) · 프렉스코리아 (정규직, 2024.07—2025.12.31) · Singapore (Remote)

한국 법인 폐업에 따라 싱가포르 본사로 IC 계약 전환, 동일 팀·동일 업무 연속 수행.

암호화폐 파생상품 거래소 Flipster 서비스 보안 전반 담당. 보안 리뷰부터 SOC, 인프라, 컴플라이언스까지 end-to-end 보안 체계 구축·운영.

3단계 Security Review Agent 파이프라인 구축 (AI 자동화)

- Code Reviewer Agent** — PR 단위 정적 분석 (인증·인가·입력 검증·민감 정보 노출)
- False Positive Validator Agent** — 데이터 흐름·기존 보안 통제 역추적, 실제 익스플로잇 가능성 재검증
- Pentest Validator Agent** — staging 환경 동적 PoC로 결론 확정
- 리뷰 소요 시간을 며칠 → PR 단위로 단축, 보안팀이 비즈니스 로직 결함·권한 설계 검토에 더 집중

Stack · Claude AI Agent · FastAPI · n8n · GitHub Actions · Python · Jira API

거래소 보안 평가(CER.live) D → AAA 등급 견인 — 90점 · 글로벌 10위

- 1년 내 **D → AA(2025.05) → AAA(2025.08)** 3단계 등급 견인. 6개 평가 영역(Server Security, User Security, ISO 27001, Insurance, Bug Bounty, Penetration Test) 갭 분석 → 우선순위·로드맵 수립
- Server Security** — SSL/TLS·HTTP Headers·SPF/DNSSEC·Cookie Flags·WAF/CDN 항목 점검 및 보강
- User Security** — Anti-Phishing Code · Device Management · Withdrawal Whitelist 신규 런칭
- Bug Bounty (HackenProof) · Penetration Test** — 프로그램 런칭·외부 펜테스팅(Web·iOS·Android 전체 스코프) 운영으로 만점 획득
- ISO 27001 / Insurance Fund** — 거버넌스 팀 주도, 보안 엔지니어 관점에서 협업 대응
- 유관 팀(Wallet · Backend · OpsX) cross-functional 추진, 평가 기관 Hacken과 커뮤니케이션·리포트 검증

Bug Bounty 프로그램 런칭·운영 (HackenProof)

- 프로그램 정책 설계 — 범위 · 보상 체계 · Triage SLA · Disclosure Policy
- Severity별 보상 체계 — Critical(CVSS 9.0–10.0) \$800–\$3,000 차등 보상
- 제보 트리아지(재현·영향도·중복 판정), 글로벌 리서처 커뮤니케이션
- HackenProof · Hacken 외부 제휴로 Cer.live 평가·펜테스팅 연계

Security Agent Bot 개발 (MCP 기반 보안팀 운영 챗봇)

- Okta · AWS · GCP · Datadog · Jira를 MCP로 연결, Slack 멘션 한 번으로 로그인 이력·IAM 권한·사고 티켓 처리
- 안전 장치 코드 고정** — MCP 외부 호출 차단, shell/JS 실행 차단, 시크릿 마스킹, 채널·DM·팀 ID 화이트리스트
- "Agent 자체가 새로운 공격 표면이 되는 것"을 가정하고 설계 → 보안팀이 직접 신뢰·사용 가능한 도구

Stack · TypeScript · Node.js · MCP · Claude Code SDK · Slack Bolt · Okta · AWS · GCP · Datadog · Jira

SDLC 보안 리뷰 프로세스 정립 및 40+건 수행

- PRD부터 출시 전까지 보안 검토 — Copy Trading, API Trading, Wallet, MFA, Passkey, OAuth 등
- Wallet Security Review 프로세스·템플릿 신규 수립 (자금 흐름·키 관리·서명 검증·출금 흐름 표준화)
- 리뷰 결과 Notion 동기화·Jira 연동, Overdue Alert 자동화
- 고위험 설계 이슈를 출시 전 차단

기타 — On-Call · DDoS 대응 · IR · Threat Modeling · Compliance

- Security On-Call Duty** — Security 엔지니어 주간 로테이션으로 24/7 보안 이벤트 모니터링·대응. Cloudflare/SIEM/CrowdStrike 알람 분석, security-request 채널 응대, 탐지 룰 튜닝, SIEM·SOAR 운영
- 20+건 DDoS 대응** — Cloudflare Managed/Custom Rule, Rate Limit, JA3/JA4 fingerprint 봇 차단, Attack Score ML
- Wallet Kill Chain Drill 주관** — BTC 무단 출금 시나리오 tabletop, CISO 참석 cross-functional 회고
- Live IR** — Malware 감염 대응 (CrowdStrike), 피싱 조사, 침입 시도 봉쇄
- Secret Audit 자동화** — Risk Scoring Engine, P0(Critical) **64건** 포함 총 83건 식별 (수 주 → 수 시간 1회 분석)
- 외부 침투 테스트 프로젝트 관리** — 다수 외부 보안 업체와 협업해 웹·모바일·인프라 펜테스팅 진행, 발견 이슈 추적 및 remediation 관리
- CIS Benchmark Golden Image** — Packer + Ansible Lockdown 기반 Ubuntu/Debian/Amazon Linux 하드닝, EKS 노드
- Threat Modeling** — 자금 유출(Fund Loss), PII 데이터 DFD 위협 모델링
- Compliance 협업 대응** — ISO 27001/27701 심사 및 VARA 라이선싱 후속(Post-IPA) 대응 시 거버넌스 팀과 협업해 보안 엔지니어 관점 항목 대응

서비스 보안 담당자로 Bug Bounty 운영·CI/CD 보안 자동화·서비스 모의해킹 등 제품 보안 영역 책임.

- › **HackerOne Bug Bounty 운영** — 정책·범위·보상 수립, 글로벌 리서처와 협업해 **301건** 처리, Jira 자동 연동
- › **CI/CD 보안 자동화** — GitHub Actions·Cloud Build에 SonarQube + OWASP ZAP, 신규 API·위협 파라미터 탐지, GKE 이미지·런타임 취약점 점검 통합. 매월 보안 이슈 **40% 감소**
- › **위협 알람·액션 앱 개발** — Splunk + Cloud Run + Pub/Sub 기반 위협 이벤트 알람·자동 액션 (IP 차단, Payload 확인), Jira 연동
- › **서비스 모의해킹 + 보안성 검토 프로세스** — 입사 후 전체 서비스 점검으로 **61건** 도출 (전년 외부 컨설팅 3건 대비), 기획·개발·QA 단계 리뷰 정착

Stack · Python · SonarQube · OWASP ZAP · GitHub Actions · GCP (GKE, Cloud Run, Pub/Sub) · Splunk · HackerOne

시큐리티허브 — 모의해킹 1팀 선임 컨설턴트 / Convergence TF Lead

2019.01 — 2022.06

정보보호 전문서비스 · 총 15개 프로젝트

- › **블랙박스 모의침투 (대기업 그룹사)** — **28개** 그룹사 외부→내부 침투, APT 시나리오 13개 수행 (AD 연구), Domain Admin 권한 탈취 다수, 자체 해킹 도구 개발
- › **금융권 모의해킹** — 은행 내부망 Endpoint 솔루션, SSO 동적 디버깅으로 전체 시스템 관리자 권한 탈취, 스마트뱅킹 보안성 심의
- › **대기업 서비스 모의해킹** — ISMS-P/ISO27001 인증 점검, 자율주행·이커머스 등 다양한 도메인. SQL Injection 유형 발굴, XSS·CSRF·SSRF 시나리오 PoC 도출
- › **IoT 취약점 방법론 연구** — 하드웨어(UART · JTAG · Flash dump) + 무선통신(Zigbee · RF · RFID · BT · WiFi) + 펌웨어 분석
- › **모바일 보안 솔루션 BMT** — Frida 기반 솔루션 우회, XecureWEB 암호화 우회

SELECTED ACHIEVEMENTS

- › **NBB-1405** — 네이버 버그바운티 XSS 제보 채택 (2020.08)
- › **거래소 보안 평가(CER) AAA · 90점 · 글로벌 10위** — Flipster 등급 건인 (2025)
- › **Bug Bounty 프로그램 2회 런칭** — HackerOne (Swit), HackenProof (Flipster)
- › **K-Shield Jr. 11기 멘토링** — 모의해킹 1팀·6팀 (2023.09)

EDUCATION

국립금오공과대학교

소프트웨어 공학 학사 · 2019.08 졸업

CERTIFICATIONS

- › **정보처리기사** — 한국산업인력공단 (2019.11)
- › **K-Shield Jr. 1기 수료** — 한국정보보호교육센터 (2018)

LINKS

Resume · kukuwhy.github.io/Resume

Blog · kukuwhy.github.io

GitHub · github.com/kukuwhy